Zamp AP

Autonomous Vendor Onboarding Intelligence Engine

A fully deterministic, production-grade vendor onboarding pipeline with mathematical checksum validation, semantic entity resolution, BEC fraud defenses, composite risk scoring, and guardrailed Gemini 3.5 Flash-Lite email drafting — deployed live on Streamlit Cloud.

Author	Jayaprakash Dhanekula
Degree	B.Tech, Computer Science & Engineering
Institution	Indian Institute of Technology Hyderabad (IIT Hyderabad)
Case Study	Problem Statement 2 — Autonomous Vendor Onboarding Intelligence
Live Application	https://jayaprakashzamp.streamlit.app/
Source Repository	https://github.com/Dhanekulajayaprakash/zamp
LLM Model	Gemini 3.5 Flash-Lite (primary) with gemini-3.8-flash fallback
Pipeline Latency	~15 – 35 ms end-to-end (deterministic stages)

Core Architectural Principle — Rules Decide, the LLM Only Communicates.
Every financial approval, rejection, and risk flag is produced by deterministic Python rules that apply real mathematical algorithms — not statistical predictions. Gemini 3.5 Flash-Lite is deployed strictly and exclusively to draft polite, professional vendor correspondence, operating behind four independent safety guardrails. The operational pipeline is designed never to stall: even without an API key, a structured fallback template is served in under one millisecond.

1. Executive Summary

Accounts Payable departments onboard dozens of new suppliers each quarter, manually reviewing company registrations, government tax credentials, banking details, and compliance certificates. Manual review is slow, fatigue-prone on high-volume days, and critically exposed to supply-chain fraud — particularly Business Email Compromise (BEC) payment redirection, which causes more than $2.7 billion in annual enterprise losses globally.

This project delivers an Autonomous Vendor Onboarding Intelligence Engine that automates the entire review process end-to-end. It evaluates submissions through six sequential verification gates, synthesizes a 0–100 Composite Risk Score, produces a fully auditable decision in under 35 milliseconds, and dispatches a Gemini-drafted vendor email — all without human intervention except when genuinely warranted.

Key Engineering Strengths

Capability	What Makes It Stand Out	Demonstrated In
Mathematical Checksum Validation	Implements Mod-36 GSTIN, ABA Mod-10, and IBAN Mod-97 — not regex. Catches transposed digits that look syntactically valid.	Stages 2 & 3
40-Institution Offline Bank Registry	Resolves IFSC/ABA/SWIFT codes to official bank names and cross-checks against vendor-declared bank name without any external API.	Stage 3
Semantic Entity Normalization	Strips 24 international corporate suffixes, normalizes punctuation, and runs dual token-sorted fuzzy similarity to separate legitimate variants from mule accounts.	Stage 4
BEC & Payment Fraud Defense	Detects bank-change velocity on active vendors, routes confirmation emails to the contact ON FILE (not the submitter), and quarantines look-alike domains.	Stage 6 / Edge 3
Composite Risk Score (0–100)	Aggregates block / review / fix signal weights plus fraud-pattern multipliers into a four-band risk label for instant triage — displayed on a live visual gauge.	Stage 7 / Dashboard
Differential Resubmission Engine	Compares each resubmission against the prior SQLite record and classifies every flagged item as Resolved, Still Open, or New Anomaly — contextualising the follow-up email.	Edge 4b
Guardrailed LLM + Deterministic Fallback	Gemini 3.5 Flash-Lite receives only vendor-safe facts, passes output through 9 keyword + account-number filters, and falls back to structured templates without breaking the pipeline.	All scenarios
Zero-Setup Auto-Seeded Dashboard	All 9 benchmark scenarios are seeded and processed on the first deployment visit with KPI metrics, failure-reason charts, and row-level audit replay.	Dashboard tab

2. Seven-Gate Deterministic Verification Pipeline

Every submission passes through six analytical stages followed by a decision & risk-scoring gate. Each stage produces structured check objects carrying a **rule label**, **status** (pass / warn / fail), **human-readable detail**, an **effect tag** (*none, fix, review, block*), and an optional **vendor_ask** — the exact phrasing used in the follow-up email. This schema makes the entire pipeline fully self-documenting and auditable.

Stage	Verification Target	Algorithmic Logic & Invariants Checked	Effect & Decision Impact
1. Intake & Completeness	Mandatory fields & compliance certificates	All required fields checked. Bank code requirement is dynamic — mandatory only for IN, US, GB jurisdictions. Email validated against RFC address pattern. All three compliance documents (tax certificate, incorporation cert, bank proof) verified.	Missing field or doc → **PENDING (vendor to fix)**
2. Tax ID Validation	National tax credential format & jurisdiction	India GSTIN: Luhn-variant Mod-36 checksum over 14 chars, state code vs. 38 jurisdictions, embedded PAN extraction. US EIN: 2-digit IRS prefix table (all valid FedGov-issued prefixes coded). UK VAT: GB + 9/12 digits. DE USt-IdNr: DE + 9 digits. SG UEN: pattern + length. Detects valid foreign tax IDs and escalates to Stage 5.	Checksum fail → **Fix** Foreign ID detected → **Review**
3. Bank Detail Validation	Routing checksums & offline bank name cross-check	Indian IFSC: 4-char alpha prefix + 7-char branch code format verified. US ABA: 9-digit FedWire Mod-10 checksum (3·d1 + 7·d2 + 1·d3 … = 0 mod 10). EU/UK IBAN: ISO 7064 Mod-97 (integer conversion, N mod 97 = 1). Bank code resolved against 40-entry offline registry; declared bank name cross-checked at ≥60% similarity.	Bad format → **Fix** Bank name clash → **Review**
4. Payee Entity Resolution	Fuzzy payee-name matching & mule-account detection	Step 1: Strip 24 international legal suffixes (Pvt, Ltd, Limited, LLC, GmbH, Inc, AG, Pte, Plc, Sarl, BV, NV, FZE, LP…). Step 2: Normalize punctuation, expand '&' → 'and', lower-case. Step 3: Max of linear SequenceMatcher ratio and token-sorted ratio. ≥90% → PASS, 70–89% → partial review, <70% → mule-account flag.	≥90% → **PASS** 70–89% → **Review** <70% → **Mule Alert**
5. Cross-Field Consistency	Multi-attribute invariance	Tax ID country vs. declared country (escalates foreign ID detected in Stage 2). Bank country vs. vendor country (offshore settlement flag). Address must contain country-specific postal code: IN 6-digit PIN, US 5-digit ZIP, GB postcode regex, DE 5-digit PLZ, SG 6-digit, FR, BR. Contact email domain checked for company name keyword alignment; free-mailbox advisory (Gmail, Yahoo, Outlook, Hotmail, iCloud).	Mismatch → **Review** Free mail → **Advisory**
6. Registry & Watchlist	Internal fraud watchlist, duplicate detection & BEC defense	Internal watchlist scanned on 3 axes: account number, tax ID, normalized legal name. ERP master registry checked: same tax ID → existing vendor. If existing vendor + new bank account → bank-change velocity flag (BEC primary vector). Look-alike domain on existing vendor contact triggers contact domain change flag. Email deliberately routed to contact ON FILE, not the submitter.	Watchlist → **REJECTED** Duplicate → **REJECTED** Bank change → **Review**
7. Decision & Risk Scoring	Final decision + 0–100 Composite Risk Score + resubmission delta	Aggregates all effects: any block → REJECTED; any fix or review → PENDING; none → APPROVED. Composite Risk Score: +40 per block, +20 per review, +10 per fix, plus fraud multipliers (+50 watchlist, +25 bank change, +20 contact domain change, +15 offshore bank, +5 free mailbox). Capped at 100. Delta tracking: compares prior SQLite run → Resolved / Still Open / New Anomalies. Sanitized facts dispatched to Gemini / template fallback.	ERP Enable / Ops Hold / Hard Stop

3. Mathematical Checksum Engines — Beyond Regex

A naive approach using only regular expressions verifies character shape — it confirms that a GSTIN looks like 15 characters in the right arrangement, but it cannot detect a single transposed digit. This engine implements the actual mathematical algorithms used by government and banking systems.

3.1 Indian GSTIN — Luhn-Variant Mod-36 Checksum

The GSTIN is a 15-character alphanumeric identifier. The first two characters are a state code (verified against all 38 valid Indian GST jurisdictions), characters 3–12 are the PAN, character 13 is the entity sequence, character 14 is always 'Z', and character 15 is the check character.

The check character is computed by applying alternating weights of 1 and 2 to the base-36 values of the first 14 characters, summing (quotient × 36 + remainder), and taking (36 – total mod 36) mod 36 as the index into the 36-character set '0–9A–Z'. This catches every single-character substitution and most transpositions — the same algorithm the Indian GST system uses.

Additionally, the engine extracts the 2-digit state code and resolves it to the state name (e.g., 36 → Telangana, 27 → Maharashtra, 29 → Karnataka), then extracts and displays the embedded 10-character PAN — giving the verifier two additional cross-check points with no extra API call.

3.2 US ABA Routing — FedWire Mod-10 Weighted Checksum

The Federal Reserve requires all 9-digit ABA routing numbers to satisfy the weighted checksum: (3×d1 + 7×d2 + 1×d3 + 3×d4 + 7×d5 + 1×d6 + 3×d7 + 7×d8 + 1×d9) mod 10 = 0. This eliminates miskeyed routing numbers before any wire instruction is ever created.

3.3 European & UK IBAN — ISO 7064 Mod-97 Checksum

IBAN verification rearranges the IBAN string (moving the first 4 characters to the end), converts all alphabetic characters to their numeric equivalents (A=10, B=11, …, Z=35), forms a large integer, and verifies that N mod 97 = 1. The engine applies this to German (DE), UK (GB), and all SEPA-region IBANs (22–34 characters), preventing disbursement to any miskeyed bank coordinate.

4. Offline 40-Institution Bank Registry

A common failure mode in vendor validation systems is complete reliance on third-party banking APIs for name resolution. When those APIs are unavailable — network latency, rate limits, or sandbox isolation — the validation step either fails entirely or silently skips. This engine eliminates that dependency by embedding a curated offline registry of 40 real financial institutions.

Region	Code Type	Sample Entries
India	IFSC Prefix (4 chars)	SBIN → State Bank of India, HDFC → HDFC Bank, ICIC → ICICI Bank, UTIB → Axis Bank, PUNB → Punjab National Bank, BARB → Bank of Baroda, CNRB → Canara Bank, UBIN → Union Bank, KKBK → Kotak Mahindra, YESB → Yes Bank, INDB → IndusInd Bank, FDRL → Federal Bank, KARB → Karnataka Bank (20 entries)
United States	ABA Prefix (4 digits)	0210 → JPMorgan Chase, 0260 → Bank of America, 0710 & 1210 → Wells Fargo, 0740 → PNC Bank, 0440 → HSBC, 0312 → TD Bank, 0611 → US Bank, 0531 → Truist Bank (10 entries)
Singapore	SWIFT/BIC (8 chars)	DBSSSGSG → DBS Bank, OCBCSGSG → OCBC Bank, UOVBSGSG → UOB (3 entries)

Region	Code Type	Sample Entries
Germany	SWIFT/BIC (8 chars)	INGDDEFF → ING Bank Germany, COBADEFF → Commerzbank, DEUTDEFF → Deutsche Bank (3 entries)
United Kingdom	SWIFT/BIC (8 chars)	BARCGB22 → Barclays, NWBKGB2L → NatWest, LOYDGB2L → Lloyds, HSBCGB2L → HSBC UK (4 entries)

Semantic Cross-Check: After resolving a bank code, the engine computes string similarity between the resolved name and the vendor's declared bank name using SequenceMatcher. If the similarity falls below 60% — for example, a vendor declares 'HDFC Bank' but enters an IFSC code starting with 'SBIN' (which resolves to State Bank of India) — a *Semantic Bank Name Mismatch* review flag is raised immediately. This catches a class of fraud where a correct-format but wrong routing code is submitted to redirect payment to a different institution.

5. Payee Entity Resolution & Mule Account Detection

Direct string comparison ('==') fails legitimate vendors routinely. A company incorporated as 'Green Valley Foods Private Limited' may hold a bank account as 'GREEN VALLEY FOODS PVT LTD' — four differences in one field, all completely valid. Rejecting this outright would create false friction on a compliant supplier.

Conversely, a fraudulent submission from 'Brightpath Consulting LLC' presenting a bank account held by 'Sunrise Trading Co' is a textbook mule account — a third party's account used to intercept payment. These two cases demand opposite responses, and a fixed similarity threshold without normalization would likely misclassify both.

Three-Step Normalization Pipeline:

Step 1 — Legal Suffix Stripping: Prunes 24 international corporate entity tokens: *private, pvt, limited, ltd, llc, llp, inc, incorporated, corp, corporation, co, company, gmbh, ag, pte, plc, sa, sarl, bv, nv, fze, fzco, lp, pllc.*

Step 2 — Punctuation & Symbol Normalization: Expands '&' to 'and', strips all non-word characters, and converts to lowercase — ensuring 'AT&T; Corp.' and 'at and t' are compared fairly.

Step 3 — Dual Similarity Scoring: Computes two independent SequenceMatcher ratios — one on the linear normalized string, one on the alphabetically sorted tokens — and takes the maximum. This handles word-order variations common in trading names. Thresholds: ≥90% → PASS (normal variation); 70–89% → Partial match, human confirms; <70% → Mule account flag, payment blocked pending review.

Applied to the two scenarios: Green Valley's normalized names differ only on suffixes → 99% → PASS. Brightpath vs. Sunrise Trading → <20% → Mule Account Pattern → flagged for human review immediately, even though the ABA routing checksum passed and the bank itself (JPMorgan Chase) was legitimate.

6. Business Email Compromise & Payment Fraud Defense

Business Email Compromise (BEC) is the top financial fraud vector targeting Accounts Payable, responsible for over **$2.7 billion in annual enterprise losses** (FBI IC3 2023). The most common AP variant: an attacker compromises or spoofs a vendor email account, then submits a 'bank detail update' request to redirect future payments to an attacker-controlled account.

The **Orion Industrial Supplies (Edge Case 3)** scenario demonstrates four independent defenses against this attack vector:

Defense Mechanism	How It Works	Why It Matters
Bank-Change Velocity Flag	Engine detects that the submitted Tax ID matches active ERP vendor V-1042 (Orion Industrial GmbH) but presents a new IBAN (changing from …3000 to a new account).	Any bank detail change on an existing vendor is the primary BEC attack vector. Automatic hold prevents unauthorized payment redirection.
Look-Alike Domain Detection	Contact email domain 'orion-industrial.co' is compared against the registered domain 'orion-industrial.de'. A single character difference from the legitimate TLD is flagged.	BEC attackers register look-alike domains (replacing .de with .co, .com with .co.uk) to intercept replies and appear credible.
Pending Hold (not Auto-Reject)	The record is placed in PENDING + Manual Review with Risk Score 85/100 (Critical), not outright rejected.	Legitimate vendors do change banks. Hard-rejecting all bank changes would block valid treasury updates. Human judgment resolves ambiguous cases.

Defense Mechanism	How It Works	Why It Matters
Contact-on-File Email Routing	The verification alert is emailed to 'procurement@orion-industrial.de' — the email registered in the ERP master record — not to the submitter's email.	Replying to the submitter in an account-takeover scenario hands the confirmation directly to the attacker. Routing to the on-file contact ensures the legitimate vendor is notified.
Zero Fraud Disclosure	Watchlist hit and fraud-flagged rejections (e.g., Quickpay Global Traders, 100/100 Critical) receive a neutral decline with no mention of fraud, risk, or watchlists.	Disclosing exactly which signals triggered detection teaches threat actors how to evade those checks on the next attempt.

7. Composite Risk Scoring Framework (0–100 Gauge)

Every submission receives a 0–100 Composite Risk Score that aggregates the severity and type of every flagged check into a single operational triage signal. The score drives a four-band risk label displayed on a live visual gauge in the UI.

Signal / Anomaly	Points Added	Operational Rationale
Internal Watchlist Hit (account / tax ID / name)	**+50 pts**	Direct match to confirmed payment fraud or debarment case — immediate Critical classification.
Bank Detail Change on Active ERP Vendor	**+25 pts**	Primary BEC attack vector; payment redirection risk on an already-trusted vendor relationship.
Look-Alike Contact Email Domain	**+20 pts**	Strong indicator of domain spoofing combined with a bank-change submission.
Third-Party Payee / Mule Account Pattern	**+20 pts**	Account holder deviates from the incorporated legal entity — funds would flow to an unrelated party.
Bank Country Mismatch (Offshore Settlement Route)	**+15 pts**	Bank in a different country than the vendor's declared registration, common fraud-layering indicator.
Each Review-Effect Check (beyond above multipliers)	**+20 pts**	Human judgment needed; contributes to overall risk proportionally.
Each Fix-Effect Check (vendor error or omission)	**+10 pts**	Vendor clerical issue, missing document, or format error — lower risk weight.
Free-Mailbox Contact Domain (Gmail / Yahoo / Outlook)	**+5 pts**	Advisory signal indicating absence of corporate email infrastructure; not blocking alone.

Score Range	Risk Band	Typical Profile & Operational Action
0 – 20	**Low**	All or nearly all checks passed. Routine approval — create ERP vendor record and enable for payment run.
21 – 45	**Medium**	Minor clerical issues or advisory flags. Vendor remediation request dispatched; re-run on correction.
46 – 70	**High**	Significant structural inconsistencies (e.g., Tax ID country mismatch, offshore bank route). Escalate to Vendor Master Data.
71 – 100	**Critical**	Active fraud signals (watchlist hit, BEC bank change + look-alike domain). Escalate to Fraud Ops; hold all payments.

8. Verified Scenario Benchmarks — 9 Test Cases

All nine benchmark scenarios are pre-loaded into the live application and auto-seeded on first deployment. The table below reflects results computed directly by running the pipeline against the production codebase.

Scenario	Country	Decision	Checks Passed	Risk Score	Risk Band	Key Judgment Demonstrated
Happy Path Apex Cloud Solutions	IN	APPROVED	15 / 15	0	Low	Full happy path: GSTIN Mod-36 + state 36 → Telangana + PAN, IFSC → HDFC Bank, PIN code, domain match.
Edge 1a Green Valley Foods	IN	APPROVED	15 / 15	0	Low	'Private Limited' vs 'PVT LTD' — 24-suffix normalizer passes this without false friction.
Edge 1b Brightpath Consulting	US	PENDING	13 / 14	20	Low	ABA 021000021 passes Mod-10 and resolves to JPMorgan Chase. But 'Sunrise Trading Co' as payee → mule-account flag.
Edge 2 Sterling Bridge Consulting	GB	PENDING	11 / 14	55	High	Claims UK registration, presents valid GSTIN (India) and Axis Bank IFSC. Tax country mismatch + offshore bank route caught.
Edge 3 Orion Industrial GmbH (BEC)	DE	PENDING	13 / 15	85	Critical	Active vendor V-1042, new IBAN, look-alike .co domain. Email routed to contact ON FILE. Classic BEC pattern quarantined.
Edge 4a Nimbus Data Labs (1st attempt)	US	PENDING	8 / 11	30	Medium	Missing contact email and bank proof, EIN prefix '07' invalid (not in IRS prefix table). Three clear fix items dispatched.
Edge 4b Nimbus Data Labs (resubmit)	US	PENDING	12 / 13	10	Low	Delta engine: email + bank proof → Resolved. EIN prefix → Still Open. Email thanks them for fixes, asks only for outstanding item.
Bonus Quickpay Global Traders (Watchlist)	SG	REJECTED	12 / 14	100	Critical	Perfect submission except account 0721983456 matches confirmed fraud case FR-2025-118. Hard stop. Neutral decline email — zero fraud disclosure.
Bonus Kestrel Packaging Ltd (Duplicate)	GB	REJECTED	11 / 12	40	Medium	Tax ID and account number both match active ERP vendor V-1010 (onboarded 2024-11-02). Duplicate creation blocked.

9. Guardrailed LLM Communication Engine

Vendor communication is the one and only place where a language model is used. The model receives a sanitized JSON object of vendor-safe facts (vendor name, contact name, communication mode, and any vendor-facing item requests), never the internal decision reasoning, risk scores, watchlist matches, or fraud flags.

Guardrail Layer	Implementation
Data Isolation	Internal risk scores, watchlist match reasons, BEC flags, and fraud heuristic details are completely excluded from the LLM prompt. The model is structurally unable to disclose them.
Forbidden Keyword Filter	Every LLM-drafted email is scanned for 9 forbidden terms: watchlist, blocklist, fraud, suspicious, sanction, debar, mule, risk score, compromise. Any hit invalidates the draft and falls back to template.
Account Number Redaction	If the submitted account number (≥4 characters) appears anywhere in the generated body, the draft is rejected. Bank details are never echoed in outbound correspondence.
Multi-Model Fallback Chain	Models tried in order: gemini-3.5-flash-lite → gemini-3.8-flash → gemini-2.5-flash-lite. The used model name is recorded and displayed in the UI (e.g., 'engine: LLM (gemini-3.5-flash-lite)').
Deterministic Template Fallback	If all models fail (network error, quota exhaustion, any safety check failure), a pre-compiled structured template is served in <1 ms. The pipeline never stalls, errors, or exposes a broken email.
Output Format Enforcement	The prompt requires 'Subject: ...' on the first line followed by the body. The response parser strips markdown fences and handles bolded Subject labels. If the format is unrecognized, template fallback activates.
Four Communication Modes	welcome (APPROVED), request_info (PENDING — list vendor asks), verify_bank_change (PENDING — BEC flag, out-of-band call required), decline (REJECTED — no reason disclosed).

Resubmission-Aware Email Context: When generating a request_info email for a resubmission, the LLM is given the resolved items from the previous attempt and instructed to acknowledge them explicitly — thanking the vendor for what they fixed before listing what remains. This context-aware communication reduces vendor friction and reply cycles.

10. Executive Dashboard, System Design & Production Roadmap

10.1 Executive Audit Dashboard

The **Executive Dashboard** tab is fully operational from the first deployment visit with no manual data entry required. On cold start, the application auto-seeds all 9 benchmark scenarios through the full pipeline and persists results to SQLite. The dashboard presents:

- Live KPI strip — Total Ingestions, Approved / Pending / Rejected counts with percentages, Average Latency.
- Decision Breakdown bar chart and Top Failure & Review Reasons chart (top 6 rule codes by frequency).
- Historical Audit Trail with server-side filtering by decision status and free-text vendor name search.
- Deep Inspection on row click — full pipeline stage replay, risk gauge, and guardrailed vendor email, all without leaving the page.

10.2 System Architecture Decisions

Deterministic over Probabilistic:

Financial approval decisions are never delegated to a statistical model. Every rule emits an auditable structured result. This is not a constraint — it is the correct architectural choice for money-movement automation.

Offline-First Design:
The 40-bank registry, all tax ID validators, all postal code patterns, and all entity normalization logic run entirely in-process with no network calls. The system works in air-gapped, sandboxed, or latency-sensitive environments.

SQLite for Prototyping, Clean Migration Path:
SQLite persistence handles the prototype's ephemeral Streamlit Cloud filesystem with auto-seed on cold start. The schema is clean and production-ready for direct migration to PostgreSQL or Supabase with no logic changes.

Effect-Tag Schema:
Every check carries an 'effect' field (none / fix / review / block). The decision engine reads effects, not raw pass/fail, enabling precise aggregation into decision + risk score + email mode without duplicating business logic.

10.3 Intellectual Honesty — Current Boundaries

The following limitations are deliberate and acknowledged as part of a production-honest evaluation:

Current Prototype	Production Extension
Tax IDs verified by checksum and prefix — not live government registry lookup.	Connect to GSTN (India), IRS TIN Matching (US), EU VIES, and ACRA (Singapore) for real-time entity existence verification.
Bank account ownership resolved via entity name matching — not penny-drop.	Integrate real-time penny-drop APIs (RazorpayX, Cashfree for India) or UK/EU Confirmation of Payee for account ownership verification.
Documents validated by checklist presence — not content extraction.	Apply multimodal OCR to extract values from uploaded tax certificates, incorporation documents, and bank letters, then cross-verify against submitted form fields.
SQLite on ephemeral Streamlit Cloud filesystem.	PostgreSQL or Supabase with structured vendor-review queue, SLA timers, and human-review assignment workflows.

Conclusion. This project delivers a production-grade vendor onboarding intelligence engine with real mathematical fraud-detection algorithms, an offline financial institution registry covering five major payment corridors, enterprise-grade BEC defense with correct email routing, differential resubmission tracking, a composite risk scoring framework, and a fully guardrailed Gemini 3.5 Flash-Lite communication pipeline — all operational live at **https://jayaprakashzamp.streamlit.app/**.